SolarSense Threat Model

Owner: Aftab Ahmed
Reviewer: Ms. Muniba Khan
Contributors: Saboor-Ul-Hassan, Muhammad Haider Zahid
Date Generated: Wed Nov 04 2026

Executive Summary

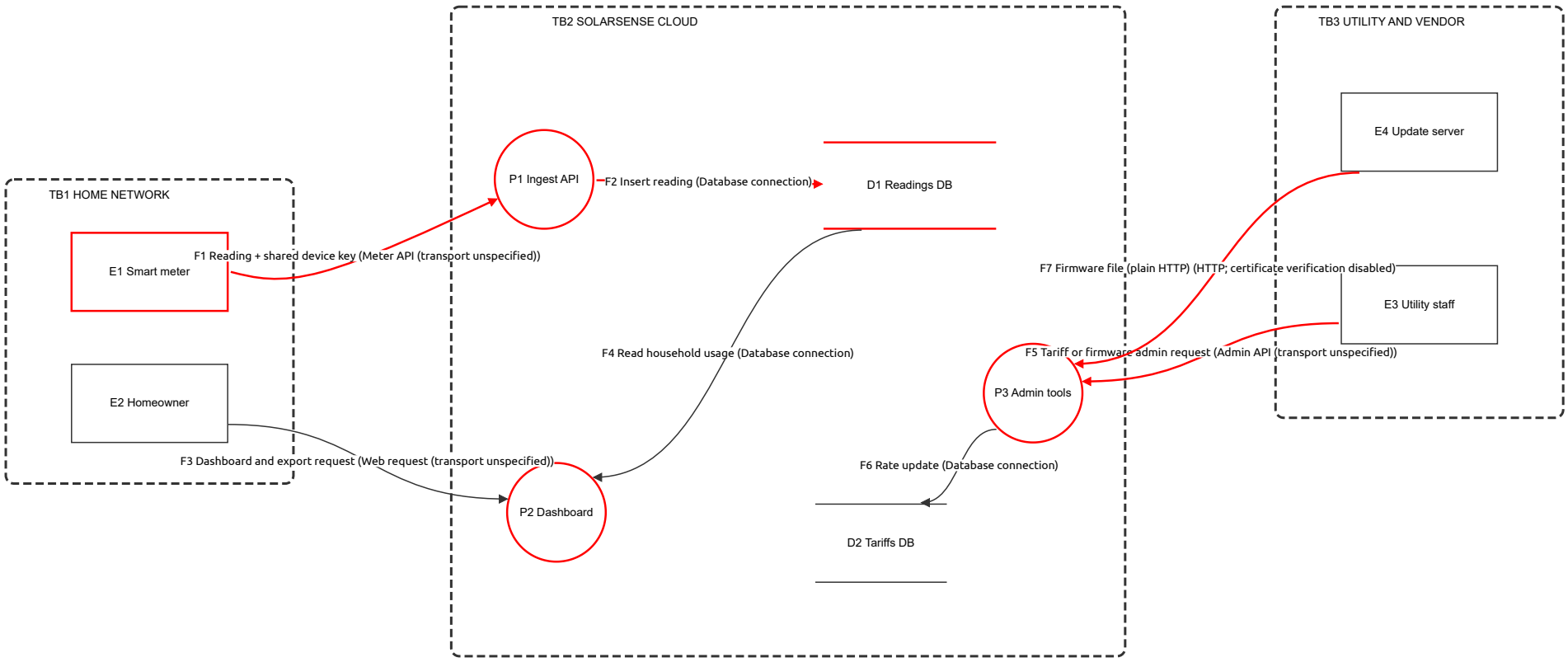
High level system description

STRIDE threat model for the SolarSense Smart Home Energy Monitor scenario. Includes the original architecture and an improved security architecture.

Summary

Total Threats	20
Total Mitigated	10
Total Open	10
Open / Critical Severity	2
Open / High Severity	7
Open / Medium Severity	1
Open / Low Severity	0

Architecture v1



Architecture v1

E1 Smart meter (Actor)

Description: IoT meter sends electricity readings.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations
9	T9: A stolen meter may expose its device credential	Spoofing	High	Open	12 (L3 x I4)	A thief with physical access to a meter may extract its credential and submit readings as that device. A shared fleet key makes the compromise affect every meter. Risk: Likelihood 3 x Impact 4 = 12.	Use unique per-device keys protected by a secure element or equivalent tamper-resistant storage. Support remote revocation, device replacement and rotation of only the affected device credential. Monitor unusual device behaviour.

P1 Ingest API (Process)

Description: Receives and validates meter readings before storing them.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations
4	T4: Reading endpoint can be exhausted by excessive requests	Denial of service	High	Open	16 (L4 x I4)	A malicious or compromised device can send a high volume of readings or oversized payloads. Without request limits and rate controls, API workers and database resources may be exhausted. Risk: Likelihood 4 x Impact 4 = 16.	Apply per-device rate limits and quotas, enforce a small request-body limit, validate payload shape before database access, configure bounded database timeouts and monitor repeated failures.

D1 Readings DB (Store)

Description: Stores meter ID, home ID, timestamp and kWh readings.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations
8	T8: Household energy data reveals sensitive occupancy patterns	Information disclosure	High	Open	12 (L3 x I4)	The readings database contains household usage history. Excessive service or staff privileges, missing ownership controls or exposed storage can reveal occupancy patterns and household routines. Risk: Likelihood 3 x Impact 4 = 12.	Enforce row-level ownership for homeowner reads, apply least-privilege database roles, encrypt sensitive data at rest and in transit, minimise retention and restrict staff access to an approved business purpose.

E2 Homeowner (Actor)

Description: Homeowner uses browser to view/export only their own usage.

Properties: Provides Authentication

Number	Title	Type	Severity	Status	Score	Description	Mitigations

P2 Dashboard (Process)

Description: Provides homeowner dashboard and export endpoints.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations
10	T10: Export path traversal reads files outside the export directory	Information disclosure	Medium	Open	8 (L2 x I4)	The export route concatenates a user supplied filename with the export directory and passes the result to send_file. A traversal sequence such as ../ may expose application files or secrets. Risk: Likelihood 2 x Impact 4 = 8.	Use send_from_directory with a fixed export directory and a validated filename. Resolve paths safely, reject traversal attempts and ensure only the authenticated owner can export their permitted data.

E3 Utility staff (Actor)

Description: Authorised utility staff manage tariffs and firmware.

Properties: Provides Authentication

Number	Title	Type	Severity	Status	Score	Description	Mitigations

P3 Admin tools (Process)

Description: Utility administrative routes for tariffs and firmware.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations
6	T6: Tariff changes have no trustworthy audit record	Repudiation	High	Open	12 (L3 x I4)	The tariff update route changes billing data without recording who performed the action, when it happened, or which values changed. A staff member could later deny making the change. Risk: Likelihood 3 x Impact 4 = 12.	Write a protected audit event for every tariff and firmware change. Record UTC timestamp, authenticated actor ID, action, target record, old value, new value and request correlation ID. Restrict alteration and deletion of audit records.

D2 Tariffs DB (Store)

Description: Stores tariff rates used for billing.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations

E4 Update server (Actor)

Description: External vendor server provides firmware files.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations

F1 Reading + shared device key (Data Flow)

Properties: Protocol (Meter API (transport unspecified))

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	T1: Shared meter key enables fleet-wide meter impersonation	Spoofing	Critical	Open	20 (L4 x I5)	All smart meters use the same static DEVICE_KEY. If the shared key is disclosed, an attacker can impersonate any meter and submit fabricated readings, potentially affecting billing across the fleet. Risk: Likelihood 4 x Impact 5 = 20.	Issue a unique per-device signing key. Keep private key material in a tamper-resistant secure element. Verify a signed payload containing the meter ID, timestamp and nonce. Reject replayed messages and provide per-device revocation and rotation.

F2 Insert reading (Data Flow)

Properties: Encrypted, Protocol (Database connection)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
7	T7: SQL injection can manipulate stored meter readings	Tampering	High	Open	12 (L3 x I4)	The ingestion endpoint interpolates meter and kWh values directly into an SQL statement. Crafted input can alter the query and corrupt or disclose database records. Risk: Likelihood 3 x Impact 4 = 12.	Validate meter identifiers and numeric reading ranges, then use parameterised SQL placeholders for all user supplied values. Give the ingestion database account only the insert permissions it requires.

F3 Dashboard and export request (Data Flow)

Properties: Protocol (Web request (transport unspecified))

Number	Title	Type	Severity	Status	Score	Description	Mitigations
3	T3: Changing home_id exposes another household's usage	Information disclosure	High	Open	16 (L4 x I4)	The dashboard trusts the caller supplied home_id. A homeowner can change the identifier in the request and retrieve readings belonging to a different household. Consumption patterns may reveal when residents are at home. Risk: Likelihood 4 x Impact 4 = 16.	Derive the homeowner identity and permitted home ID from the authenticated session. Perform an ownership check on every dashboard request and use parameterised SQL. Deny by default and return 403 for a non-owned home.

F4 Read household usage (Data Flow)

Properties: Encrypted, Protocol (Database connection)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

F5 Tariff or firmware admin request (Data Flow)

Properties: Protocol (Admin API (transport unspecified))

Number	Title	Type	Severity	Status	Score	Description	Mitigations
5	T5: A homeowner or outsider can invoke utility administration actions	Elevation of privilege	High	Open	15 (L3 x I5)	The tariff and firmware administration routes do not enforce a utility_staff role. A low-privileged caller may reach operations intended only for utility staff and alter tariffs or trigger firmware actions. Risk: Likelihood 3 x Impact 5 = 15.	Require an authenticated session and an explicit utility_staff role on every administrative route. Deny by default, separate staff privileges from homeowner privileges and recheck authorization on each request.

F6 Rate update (Data Flow)

Properties: Encrypted, Protocol (Database connection)

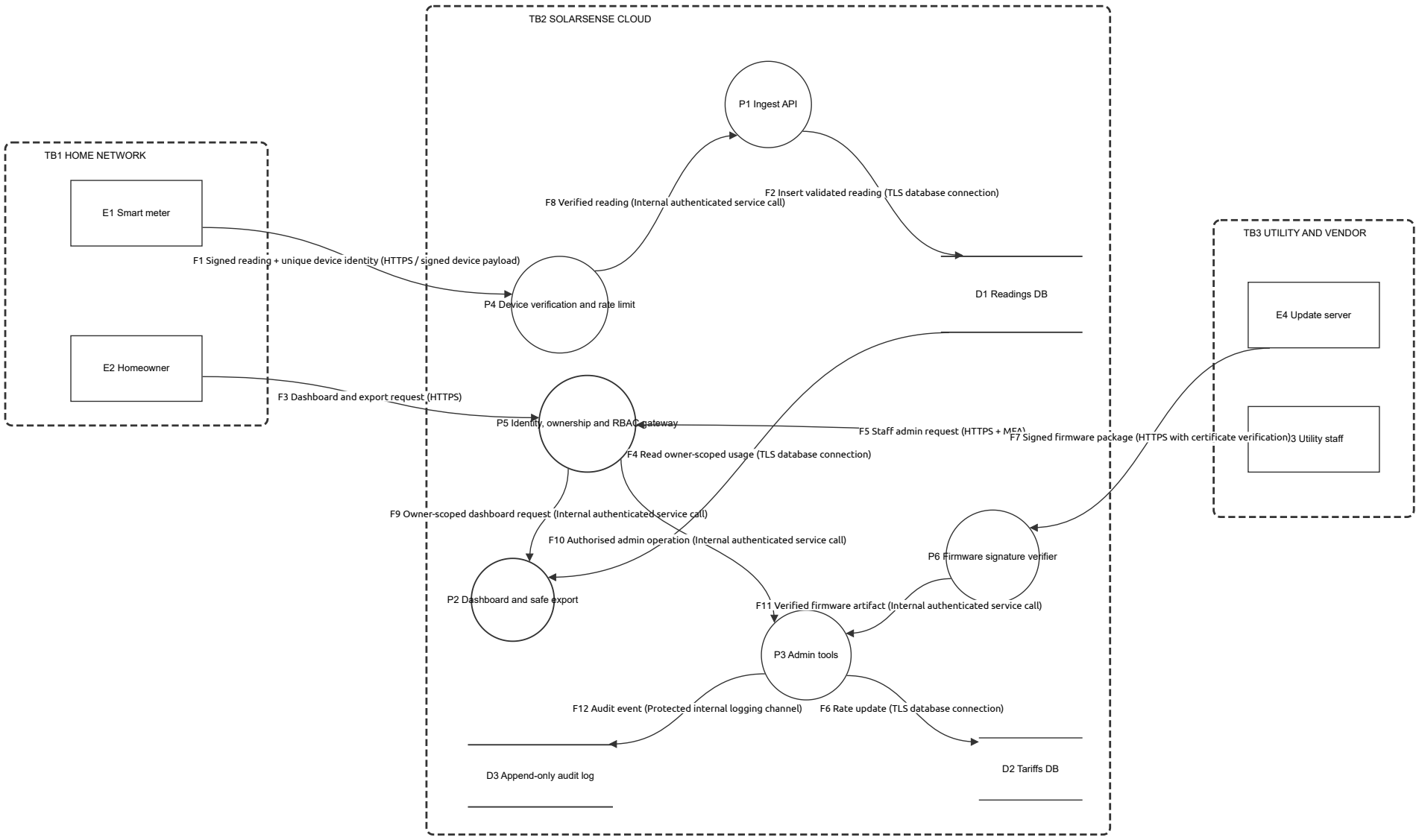
Number	Title	Type	Severity	Status	Score	Description	Mitigations

F7 Firmware file (plain HTTP) (Data Flow)

Properties: Protocol (HTTP; certificate verification disabled)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
2	T2: Firmware can be replaced during an unverified download	Tampering	Critical	Open	20 (L4 x I5)	The firmware endpoint downloads from plain HTTP and sets verify=False. A network attacker or compromised intermediary could replace the firmware package before it reaches the cloud service. Risk: Likelihood 4 x Impact 5 = 20.	Fetch firmware only over HTTPS with certificate verification enabled. Independently verify a vendor digital signature over the complete firmware artifact before accepting or distributing it. Reject invalid signatures and log failures.

Architecture v2



Architecture v2

E1 Smart meter (Actor)

Description: IoT meter holds its unique signing key in a tamper-resistant secure element.

Properties: Provides Authentication

Number	Title	Type	Severity	Status	Score	Description	Mitigations
9	T9: A stolen meter may expose its device credential	Spoofing	High	Mitigated	12 (L3 x I4)	A thief with physical access to a meter may extract its credential and submit readings as that device. A shared fleet key makes the compromise affect every meter. Risk: Likelihood 3 x Impact 4 = 12.	Use unique per-device keys protected by a secure element or equivalent tamper-resistant storage. Support remote revocation, device replacement and rotation of only the affected device credential. Monitor unusual device behaviour.

P4 Device verification and rate limit (Process)

Description: Verifies a unique per-device signature, timestamp and nonce. Applies per-device rate limits and payload-size limits.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations
4	T4: Reading endpoint can be exhausted by excessive requests	Denial of service	High	Mitigated	16 (L4 x I4)	A malicious or compromised device can send a high volume of readings or oversized payloads. Without request limits and rate controls, API workers and database resources may be exhausted. Risk: Likelihood 4 x Impact 4 = 16.	Apply per-device rate limits and quotas, enforce a small request-body limit, validate payload shape before database access, configure bounded database timeouts and monitor repeated failures.

P1 Ingest API (Process)

Description: Accepts only verified readings and inserts validated values using parameterised SQL.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations

D1 Readings DB (Store)

Description: Stores encrypted meter readings and home ownership mappings. Application access is least-privilege.

Properties: Encrypted

Number	Title	Type	Severity	Status	Score	Description	Mitigations
8	T8: Household energy data reveals sensitive occupancy patterns	Information disclosure	High	Mitigated	12 (L3 x I4)	The readings database contains household usage history. Excessive service or staff privileges, missing ownership controls or exposed storage can reveal occupancy patterns and household routines. Risk: Likelihood 3 x Impact 4 = 12.	Enforce row-level ownership for homeowner reads, apply least-privilege database roles, encrypt sensitive data at rest and in transit, minimise retention and restrict staff access to an approved business purpose.

E2 Homeowner (Actor)

Description: Homeowner authenticates and can access only the household associated with the session.

Properties: Provides Authentication

Number	Title	Type	Severity	Status	Score	Description	Mitigations

P5 Identity, ownership and RBAC gateway (Process)

Description: Authenticates users, enforces home ownership for homeowners, enforces utility_staff role for admin endpoints, and applies access rate limits.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations

P2 Dashboard and safe export (Process)

Description: Returns only owner-scoped usage data. Uses a fixed export directory and send_from_directory.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations
10	T10: Export path traversal reads files outside the export directory	Information disclosure	Medium	Mitigated	8 (L2 x I4)	The export route concatenates a user supplied filename with the export directory and passes the result to send_file. A traversal sequence such as ../ may expose application files or secrets. Risk: Likelihood 2 x Impact 4 = 8.	Use send_from_directory with a fixed export directory and a validated filename. Resolve paths safely, reject traversal attempts and ensure only the authenticated owner can export their permitted data.

P3 Admin tools (Process)

Description: Changes tariffs and handles accepted firmware only after staff role checks and logs each change.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations

D2 Tariffs DB (Store)

Description: Stores tariff rates. Only the admin service can update records.

Properties: Encrypted

Number	Title	Type	Severity	Status	Score	Description	Mitigations

E3 Utility staff (Actor)

Description: Utility staff authenticate with an individual staff account and MFA.

Properties: Provides Authentication

Number	Title	Type	Severity	Status	Score	Description	Mitigations

E4 Update server (Actor)

Description: External vendor publishes signed firmware packages.

Properties: Provides Authentication

Number	Title	Type	Severity	Status	Score	Description	Mitigations

P6 Firmware signature verifier (Process)

Description: Downloads firmware using HTTPS with certificate verification, then verifies the vendor signature and version before forwarding it.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations

D3 Append-only audit log (Store)

Description: Protected audit records include actor, UTC time, action, target and before/after values.

Properties: Is a Log, Encrypted

Number	Title	Type	Severity	Status	Score	Description	Mitigations

F1 Signed reading + unique device identity (Data Flow)

Description: Only a per-device credential is accepted.

Properties: Encrypted, Protocol (HTTPS / signed device payload)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	T1: Shared meter key enables fleet-wide meter impersonation	Spoofing	Critical	Mitigated	20 (L4 x I5)	All smart meters use the same static DEVICE_KEY. If the shared key is disclosed, an attacker can impersonate any meter and submit fabricated readings, potentially affecting billing across the fleet. Risk: Likelihood 4 x Impact 5 = 20.	Issue a unique per-device signing key. Keep private key material in a tamper-resistant secure element. Verify a signed payload containing the meter ID, timestamp and nonce. Reject replayed messages and provide per-device revocation and rotation.

F8 Verified reading (Data Flow)

Description: Only payloads that pass signature, freshness and quota checks proceed.

Properties: Encrypted, Protocol (Internal authenticated service call)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

F2 Insert validated reading (Data Flow)

Description: Parameterized database insert.

Properties: Encrypted, Protocol (TLS database connection)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
7	T7: SQL injection can manipulate stored meter readings	Tampering	High	Mitigated	12 (L3 x I4)	The ingestion endpoint interpolates meter and kWh values directly into an SQL statement. Crafted input can alter the query and corrupt or disclose database records. Risk: Likelihood 3 x Impact 4 = 12.	Validate meter identifiers and numeric reading ranges, then use parameterised SQL placeholders for all user supplied values. Give the ingestion database account only the insert permissions it requires.

F3 Dashboard and export request (Data Flow)

Description: Homeowner identity is authenticated at the gateway.

Properties: Encrypted, Protocol (HTTPS)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
3	T3: Changing home_id exposes another household’s usage	Information disclosure	High	Mitigated	16 (L4 x I4)	The dashboard trusts the caller supplied home_id. A homeowner can change the identifier in the request and retrieve readings belonging to a different household. Consumption patterns may reveal when residents are at home. Risk: Likelihood 4 x Impact 4 = 16.	Derive the homeowner identity and permitted home ID from the authenticated session. Perform an ownership check on every dashboard request and use parameterised SQL. Deny by default and return 403 for a non-owned home.

F9 Owner-scoped dashboard request (Data Flow)

Description: The gateway supplies a session-derived home scope.

Properties: Encrypted, Protocol (Internal authenticated service call)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

F4 Read owner-scoped usage (Data Flow)

Description: Queries are constrained to the authorised home.

Properties: Encrypted, Protocol (TLS database connection)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

F5 Staff admin request (Data Flow)

Description: Only authenticated utility_staff requests are forwarded.

Properties: Encrypted, Protocol (HTTPS + MFA)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
5	T5: A homeowner or outsider can invoke utility administration actions	Elevation of privilege	High	Mitigated	15 (L3 x I5)	The tariff and firmware administration routes do not enforce a utility_staff role. A low-privileged caller may reach operations intended only for utility staff and alter tariffs or trigger firmware actions. Risk: Likelihood 3 x Impact 5 = 15.	Require an authenticated session and an explicit utility_staff role on every administrative route. Deny by default, separate staff privileges from homeowner privileges and recheck authorization on each request.

F10 Authorised admin operation (Data Flow)

Description: Role authorization is checked on every request.

Properties: Encrypted, Protocol (Internal authenticated service call)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

F6 Rate update (Data Flow)

Description: Only the admin service can update tariff records.

Properties: Encrypted, Protocol (TLS database connection)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

F7 Signed firmware package (Data Flow)

Description: The vendor package is independently signature-verified.

Properties: Encrypted, Protocol (HTTPS with certificate verification)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
2	T2: Firmware can be replaced during an unverified download	Tampering	Critical	Mitigated	20 (L4 x I5)	The firmware endpoint downloads from plain HTTP and sets verify=False. A network attacker or compromised intermediary could replace the firmware package before it reaches the cloud service. Risk: Likelihood 4 x Impact 5 = 20.	Fetch firmware only over HTTPS with certificate verification enabled. Independently verify a vendor digital signature over the complete firmware artifact before accepting or distributing it. Reject invalid signatures and log failures.

F11 Verified firmware artifact (Data Flow)

Description: Only firmware with a valid trusted signature is accepted.

Properties: Encrypted, Protocol (Internal authenticated service call)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

F12 Audit event (Data Flow)

Description: Every sensitive administrative action is recorded in the append-only log.

Properties: Encrypted, Protocol (Protected internal logging channel)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
6	T6: Tariff changes have no trustworthy audit record	Repudiation	High	Mitigated	12 (L3 x I4)	The tariff update route changes billing data without recording who performed the action, when it happened, or which values changed. A staff member could later deny making the change. Risk: Likelihood 3 x Impact 4 = 12.	Write a protected audit event for every tariff and firmware change. Record UTC timestamp, authenticated actor ID, action, target record, old value, new value and request correlation ID. Restrict alteration and deletion of audit records.